

SWYNEX

Security Assessment Report

Task 4 – Final Defensive Security Assessment

Assessment Type	Defensive Security Assessment
Environment	Authorized Local Training Lab
Primary Application	OWASP Juice Shop
Application Address	http://localhost:3000
Assessment Areas	Security Fundamentals; Network Security Analysis; Web Security Review

1. Executive Summary

This report presents the results of a defensive security assessment performed in authorized local laboratory environments as part of the SWYNEX Cyber Security Internship. The assessment covered security fundamentals, network traffic analysis, and web application security review using intentionally vulnerable training environments.

The assessment identified SQL injection leading to authentication bypass, Cross-Site Scripting (XSS), exposed web-accessible files, and unencrypted HTTP traffic in the local test environment. All testing was performed only against authorized local training applications. No third-party or unauthorized systems were targeted.

2. Assessment Objectives

- Identify common security vulnerabilities in an authorized training environment.
- Analyze network traffic and identify protocols and security concerns.
- Review web application security weaknesses.
- Collect evidence for identified findings.
- Assess potential risk and impact.
- Provide practical remediation recommendations.
- Document the assessment professionally.

3. Scope and Authorized Environment

The assessment used intentionally vulnerable training applications running locally on the assessment machine. The primary application was OWASP Juice Shop at http://localhost:3000. Network analysis was performed on local traffic generated by the Juice Shop application. No external or third-party systems were tested.

4. Tools Used

- OWASP Juice Shop
- Docker Desktop
- Wireshark
- Npcap
- Google Chrome

- PowerShell
- Windows

5. Methodology

- Set up OWASP Juice Shop locally using Docker.
- Performed controlled security testing against selected application functionality.
- Captured and analyzed local network traffic using Wireshark.
- Identified security weaknesses and insecure communication patterns.
- Captured screenshots as evidence.
- Evaluated severity and potential impact.
- Developed remediation recommendations.
- Consolidated findings into this final report.

6. Findings Summary

Finding	Severity	Main Risk
SQL Injection / Authentication Bypass	High	Authentication bypass and unauthorized access
Cross-Site Scripting (XSS)	Medium	Client-side script execution
Exposed Web-Accessible File	Medium	Information disclosure
Unencrypted HTTP Traffic in Local Lab	Medium	Possible interception or modification if exposed to an untrusted network

7. Finding 1 – SQL Injection / Authentication Bypass

Affected Component: Login / Authentication functionality

Description: A controlled SQL injection test was performed against the login functionality of the intentionally vulnerable OWASP Juice Shop application. The application accepted the test input and allowed authentication to be bypassed.

Evidence: A successful login/challenge completion was observed during the authorized local test.

Severity: High

Potential Impact: An attacker could potentially bypass authentication and gain unauthorized access to user accounts or privileged application functionality.

Recommended Remediation:

- Use parameterized queries and prepared statements.
- Never construct SQL queries directly from user input.
- Apply server-side input validation.
- Implement secure authentication mechanisms.
- Use least-privilege database permissions.

Evidence Reference: Finding-1-SQL-Injection-Login-Bypass.png

8. Finding 2 – Cross-Site Scripting (XSS)

Affected Component: Search functionality

Description: A controlled XSS test was performed through the search functionality. During the authorized local test, JavaScript alert execution was observed in the browser, demonstrating client-side script injection behavior in the

intentionally vulnerable training application.

Evidence: The controlled XSS payload was submitted through the Juice Shop search functionality and JavaScript execution was observed during the test.

Severity: Medium

Potential Impact: XSS can allow malicious scripts to execute in a user's browser and may lead to unauthorized actions, session-related attacks, or manipulation of application content.

Recommended Remediation:

- Validate and sanitize user input.
- Apply context-aware output encoding.
- Avoid inserting untrusted input directly into HTML or JavaScript.
- Implement an appropriate Content Security Policy (CSP).

Evidence Reference: Finding-2-XSS.png

9. Finding 3 – Exposed Web-Accessible File

Affected Component: FTP/File area

Description: The file /ftp/legal.md was directly accessible through the local web application.

Evidence: The file was retrieved through its web-accessible local path.

Severity: Medium

Potential Impact: If sensitive, internal, backup, configuration, or restricted files are stored in publicly accessible directories, unauthorized users could retrieve information that should not be exposed.

Recommended Remediation:

- Remove sensitive files from web-accessible directories.
- Apply appropriate authorization controls.
- Restrict access to internal files.
- Review server configuration and file permissions.
- Regularly audit publicly accessible resources.

Evidence Reference: Finding-3-Exposed-File.png

10. Finding 4 – Unencrypted HTTP Traffic

Affected Component: Local Juice Shop web communication

Description: Wireshark was used to capture and analyze local traffic generated while accessing the Juice Shop application. TCP traffic on port 3000 and HTTP requests/responses were observed, including application and JavaScript resource requests.

Evidence: Wireshark TCP and HTTP traffic screenshots from the authorized local analysis.

Severity: Medium

Potential Impact: HTTP traffic is not encrypted. If a similar service were exposed over an untrusted network, traffic could potentially be observed or modified.

Recommended Remediation:

- Use HTTPS/TLS for production web applications.
- Redirect HTTP traffic to HTTPS.

- Configure secure TLS settings and certificates.
- Avoid transmitting sensitive information over unencrypted HTTP.

Evidence Reference: Wireshark TCP and HTTP evidence screenshots

11. Overall Security Recommendations

- Use secure coding practices.
- Validate and sanitize user-controlled input.
- Use parameterized database queries.
- Implement strong authentication and authorization.
- Apply proper output encoding to prevent XSS.
- Restrict access to sensitive files and directories.
- Use HTTPS/TLS for production services.
- Keep software dependencies and server components updated.
- Perform regular security assessments.
- Follow the principle of least privilege.
- Maintain appropriate security logging and monitoring.

12. Evidence Collected

- Finding-1-SQL-Injection-Login-Bypass.png
- Finding-2-XSS.png
- Finding-3-Exposed-File.png
- Wireshark TCP traffic screenshot
- Wireshark HTTP traffic screenshot

13. Limitations

This assessment was performed only within authorized local training environments. OWASP Juice Shop was intentionally vulnerable and was used for educational and defensive security testing. The findings should not be interpreted as vulnerabilities in third-party or production systems. No unauthorized systems, external websites, or third-party infrastructure were targeted.

14. Conclusion

The security assessment demonstrated practical security testing and defensive analysis across multiple cybersecurity areas. It identified and documented SQL injection/authentication bypass, XSS, exposed file access, and unencrypted HTTP communication. Evidence, risk, impact, and remediation recommendations were documented for each finding.

15. Submission Information

Repository Name	SWYNEX-Security-Assessment-Report
Assessment Environment	Authorized Local OWASP Juice Shop Training Lab
Assessment Areas	Security Fundamentals; Network Security Analysis; Web Security Review; Final Security Assessment